

1. Атаки Command Injections

1.1 Обнаружение уязвимости

1.1.1 Шаг 1: Базовый тест Вводим IP и добавляем команду с разделителем:

```
127.0.0.1; whoami
```

1.1.2 Шаг 2: Анализ ответа

Ответ	Значение
Вывод ping + вывод whoami	Уязвимость подтверждена
Invalid input	Есть фильтр (WAF/blacklist)
Только ping	Команда выполнялась, но вывод не виден (blind)

Если видим Invalid input — это может быть:

- Клиентская валидация (HTML5 pattern)
- Back-end фильтр (blacklist символов)
- WAF блокировка

1.2 Обход клиентской валидации

1.2.1 Проблема HTML5 pattern не дает отправить форму с инъекцией.

1.2.2 Решения

1. Отключить JavaScript в браузере
2. Использовать Burp Suite для перехвата и изменения запроса
3. Использовать curl напрямую
4. Удалить атрибут pattern через DevTools (F12)

1.2.3 Определение Front-end валидации Если при вводе появляется сообщение без отправки запроса — это клиентская валидация.

Пример: Ввод 127.0.0.1; whoami вызывает “Please match the requested format” — значит валидация на фронтенде.

1.3 Тестирование операторов

1.3.1 Semicolon ; Выполняет обе команды подряд.

```
127.0.0.1; whoami
```

1.3.2 Pipe | Передает вывод первой команды во вторую. Показывает только вывод второй.

```
127.0.0.1 | whoami
```

1.3.3 AND && Выполняет вторую, только если первая успешна.

```
127.0.0.1 && whoami
```

1.3.4 OR || Выполняет вторую, только если первая провалилась.

```
127.0.0.1 || whoami
```

1.3.5 New Line %0a Заменяет перенос строки. Часто не блокируется фильтрами.

```
127.0.0.1%0awhoami
```

Результат: %0a часто не блокируется, так как может быть нужен в самом payload. Это делает его главным оператором для обхода фильтров.

1.4 Работа с Burp Suite

1.4.1 Настройка прокси

1. Firefox → Settings → Network Settings
2. Manual Proxy: 127.0.0.1:8080
3. Burp → Proxy → Intercept → On

1.4.2 Перехват запроса

1. Отправить запрос через браузер
2. Перехватить в Burp
3. Отправить в Repeater (Ctrl+R)

1.4.3 Изменение параметров

1. Вкладка Params (для GET) или Body (для POST)
2. Найти параметр (например, ip)
3. Изменить значение на payload
4. URL-кодирование (Ctrl+U)

Важно: GET-параметры находятся в URL и отображаются во вкладке Params. Если параметра нет в теле запроса — смотрите в URL.

1.5 Методы эксплуатации

1.5.1 Прямой вывод (In-band) Когда команда выполняется и вывод виден сразу в ответе.

Пример: Подстановка whoami в ping команду дает вывод www-data.

1.5.2 Слепой (Blind) Когда вывод не виден, нужно использовать:

- Задержки (sleep)
- DNS-запросы
- Вывод в файл с последующим чтением

1.5.3 Out-of-Band Команда выполняется, результат передается через другой канал (например, DNS).

1.6 Как работает фильтрация

1.6.1 Blacklist (Черный список) Проверка наличия запрещенных символов или слов.

```
$blacklist = ['&', '|', ';', 'whoami', 'cat'];  
foreach ($blacklist as $word) {
```

```
if (strpos($_POST['ip'], $word) !== false) {  
    echo "Invalid input";  
}  
}
```

1.6.2 Whitelist (Белый список) Проверка соответствия разрешенному формату.

```
if (filter_var($_GET['ip'], FILTER_VALIDATE_IP)) {  
    // call function  
} else {  
    // deny request  
}
```

1.6.3 WAF Анализирует запрос на наличие аномалий и известных паттернов атак.

Важно: Черные списки легко обходятся. Белые списки и WAF — более надежная защита.